VECTONIX TECHNOLOGIES

Winter Internship 2026

CYBERSECURITY &

ETHICAL HACKING HANDBOOK

Protect, Detect, Respond — Ethical Hacking for Beginners

IMPORTANT: All practical exercises must be performed only on systems you own or have explicit written permission to test.

vectonix.in | 25 November – 25 December 2026

WARNING

LEGAL DISCLAIMER: This handbook is for educational purposes only. All security testing and hacking techniques described here must only be practised in legal, authorized lab environments such as your own virtual machines or platforms like DVWA and HackTheBox (with a valid account). Never test any technique on systems, networks, or websites you do not own or have written permission to test. Unauthorized access to computer systems is a criminal offence in most countries and can result in severe penalties.

Table of Contents

Ch.	Topic
1	Introduction to Cybersecurity
2	Computer Networks
3	Linux Fundamentals
4	Cybersecurity Fundamentals
5	Web Application Security — OWASP Top 10
6	Security Testing Tools
7	Vulnerability Assessment
8	Python for Cybersecurity
P	Practical Projects
R	Resources & Glossary

CHAPTER 1

Introduction to Cybersecurity

Why digital security matters in today's world

1.1 What is Cybersecurity?

Cybersecurity is the practice of protecting computers, servers, networks, and data from digital attacks, damage, or unauthorized access. Just as you lock your house and car to keep them safe, cybersecurity 'locks' your digital world.

Every 39 seconds, a hacker attempts an attack somewhere in the world. In 2023, cybercrime cost the world over $8 trillion. Cybersecurity professionals are the defenders who prevent, detect, and respond to these attacks.

1.2 Types of Cyberattacks

Attack Type	What It Is	Real Example
Phishing	Fake emails/messages to steal credentials	Fake bank email asking for password
Malware	Malicious software on your device	Ransomware encrypting hospital records
DDoS	Flooding a server with requests to crash it	Gaming site taken offline during tournament
SQL Injection	Injecting code into database queries	Attacker extracts all user passwords
Man-in-the-Middle	Intercepting communication	Stealing data on public Wi-Fi
Social Engineering	Manipulating people instead of systems	Pretending to be IT support

1.3 The CIA Triad

The CIA Triad is the foundation of cybersecurity. Every security decision protects one or more of these three principles:

Principle	Meaning	Example	How to Protect
Confidentiality	Only authorised people can access data	Only you can read your email	Encryption, access control, passwords
Integrity	Data is accurate and has not been tampered with	Your bank balance is correct	Hashing, digital signatures, audit logs
Availability	Systems are accessible when needed	Website is online 99.9% of the time	Backups, DDoS protection, redundancy

1.4 Ethical Hacking vs Malicious Hacking

Aspect	Ethical Hacker (White Hat)	Malicious Hacker (Black Hat)

Permission	Always has written permission	Never has permission
Goal	Find vulnerabilities to fix them	Exploit vulnerabilities for gain
Outcome	Security report with fixes	Data theft, damage, disruption
Legality	Completely legal	Criminal offence
Employment	Hired by organisations	Arrested and prosecuted

1.5 Cybersecurity Career Paths

Role	What You Do	Skills Needed
Security Analyst	Monitor systems, detect threats	SIEM, log analysis, networking
Penetration Tester	Find vulnerabilities ethically	Kali Linux, Burp Suite, scripting
SOC Analyst	24/7 monitoring, incident response	SIEM, threat intelligence
Security Engineer	Design and build security systems	Cloud security, firewalls, IAM
CISO	Lead organisation's security strategy	Leadership, risk management, compliance

Chapter 1 — Exercises

Part A: Multiple Choice Questions

1. What does CIA stand for in cybersecurity?

- A) Central Intelligence Agency
- B) Confidentiality, Integrity, Availability
- C) Computer Internet Architecture
- D) Cyber Intrusion Analysis

2. A phishing attack typically targets:

- A) Physical hardware
- B) Operating system bugs
- C) People through fake messages
- D) Database servers

3. What is an ethical hacker also called?

- A) Black hat
- B) Gray hat
- C) White hat
- D) Red hat

4. Which CIA principle ensures data is not altered by unauthorised parties?

- A) Confidentiality
- B) Availability
- C) Integrity
- D) Authentication

5. What does DDoS stand for?

- A) Direct Denial of Service
- B) Distributed Denial of Service
- C) Dynamic DNS over SSL
- D) Data Destruction over Systems

Part B: Short Answer Questions

1. In your own words, explain the CIA Triad with a real-world example for each component.

2. What is the main difference between a penetration tester and a criminal hacker?

3. Name three types of cyberattacks and explain how each one works.

4. Why is cybersecurity important for small businesses, not just large corporations?

5. What is social engineering and why is it effective?

Part C: Practical Exercises

Exercise 1: Research a real-world data breach (e.g., Equifax 2017, Yahoo 2016). Write a 200-word summary: what happened, how many people were affected, what vulnerability was exploited, and what could have prevented it.

Exercise 2: Create a personal cybersecurity checklist: list 10 actions someone can take to improve their own digital security (passwords, MFA, updates, etc.).

Part D: Scenario

Your college is concerned about cybersecurity after a ransomware attack hit a nearby university. The principal asks you to explain what cybersecurity is, what threats exist, and what three immediate steps the college should take. Write your 300-word response.

Answer Key

• MCQ: 1-B, 2-C, 3-C, 4-C, 5-B

• Short 1: C=only you see your message(encryption), I=message not changed(hashing), A=service always works(uptime).

• Short 2: Penetration tester has written permission and reports findings; criminal hacker has no permission and harms.

• Short 3: Phishing=fake emails; Malware=malicious software; SQL Injection=code in database queries.

• Short 4: Small businesses hold customer data; often less protected; 43% of attacks target small businesses.

• Short 5: Exploits human psychology (trust, fear, urgency) rather than technical bugs; effective because humans are the weakest link.

CHAPTER 2

Computer Networks

How Computers Communicate — The Foundation of Cybersecurity

2.1 What is a Network?

A computer network is a group of devices connected together to share resources and communicate. Like a postal system: devices are houses, IP addresses are house numbers, and data packets are letters.

2.2 Network Types

Type	Full Name	Scope	Example
LAN	Local Area Network	Building/campus	Your home Wi-Fi, office network
WAN	Wide Area Network	Country/global	The internet itself
MAN	Metropolitan Area Network	City	City-wide broadband network

2.3 IP Addresses and Ports

An IP address is a unique number given to each device on a network. Like a home address for data to find its destination.

```
IPv4 format: 192.168.1.1 (four numbers, each 0-255)
Private IPs: 192.168.x.x, 10.x.x.x, 172.16-31.x.x (used inside networks)
Public IPs: All other ranges (visible on the internet)

A port is a numbered channel within an IP address.
Port 80 = HTTP (web traffic, unencrypted)
Port 443 = HTTPS (web traffic, encrypted)
Port 22 = SSH (remote server access)
Port 21 = FTP (file transfer)
Port 3306 = MySQL database
Port 3389 = RDP (Windows Remote Desktop)
```

2.4 DNS — Domain Name System

DNS translates human-readable domain names into IP addresses. You type vectonix.in, DNS finds its IP.

Step	What Happens
1. You type vectonix.in	Browser checks its local cache first
2. Cache miss	Browser asks your ISP's DNS resolver
3. DNS resolver	Asks root nameservers, then TLD (.in), then authoritative DNS
4. IP returned	DNS says: vectonix.in = 104.21.x.x

5. Connection	Browser connects to that IP address

2.5 HTTP vs HTTPS

Feature	HTTP	HTTPS
Encryption	No — data is plain text	Yes — TLS/SSL encrypted
Port	80	443
Security	Anyone can intercept	Encrypted end-to-end
URL	http://...	https://...
Use today	Mostly obsolete for sensitive data	Required for all modern sites

2.6 TCP vs UDP

Feature	TCP	UDP
Reliability	Guaranteed delivery	No guarantee
Speed	Slower (handshake)	Faster
Order	Packets arrive in order	No ordering
Use case	Web, email, file transfer	Video calls, gaming, DNS

Chapter 2 — Exercises

Part A: Multiple Choice Questions

1. What is an IP address used for?

- A) Storing files
- B) Identifying a device on a network
- C) Encrypting data
- D) Running programs

2. Which port does HTTPS use by default?

- A) 80
- B) 8080
- C) 443
- D) 22

3. What does DNS do?

- A) Encrypts web traffic
- B) Translates domain names to IP addresses
- C) Assigns ports to services
- D) Manages firewall rules

4. Which protocol guarantees packet delivery?

- A) UDP
- B) HTTP
- C) TCP
- D) DNS

5. What is a private IP address?

- A) An IP used only on the internet
- B) An IP used inside a local network
- C) A hidden IP
- D) An IPv6 address

Part B: Short Answer Questions

1. Explain the difference between a public IP and a private IP with examples.

2. What is a port number? Why are port numbers important in cybersecurity?

3. Describe what happens step by step when you visit a website.

4. Why is HTTPS more secure than HTTP?

5. When would a developer choose UDP over TCP?

Part C: Practical Exercises

Exercise 1: Open a terminal and run: ping google.com, then nslookup google.com. Record and explain the output.

Exercise 2: Use your browser's developer tools (F12) to inspect the Network tab when loading a website. Identify 3 HTTP requests and their status codes.

Part D: Scenario

You are at a coffee shop using public Wi-Fi. Explain the risks, what information an attacker on the same network could capture, and what steps you should take to protect yourself.

Answer Key

• MCQ: 1-B, 2-C, 3-B, 4-C, 5-B

• Short 1: Public IP visible on internet (e.g., 8.8.8.8); Private IP inside network (e.g., 192.168.1.1).

• Short 2: A port is a numbered channel; different services run on different ports; attackers scan for open ports.

• Short 3: DNS resolves domain → browser sends HTTP request → server responds → browser renders HTML.

• Short 4: HTTPS uses TLS to encrypt data; HTTP is plain text readable by anyone on the network.

• Short 5: When speed matters more than reliability: video streaming, online gaming, VoIP calls.

CHAPTER 3

Linux Fundamentals

The Operating System of Cybersecurity Professionals

3.1 Why Linux for Cybersecurity?

Most security tools, servers, and hacking tools run on Linux. Kali Linux is the go-to operating system for ethical hackers — it comes with 600+ security tools pre-installed. Learning Linux is essential for any cybersecurity career.

3.2 Essential Commands Reference

Command	Syntax	What It Does	Example
pwd	pwd	Show current directory	Output: /home/student
ls	ls -la	List files with permissions	Shows hidden files too
cd	cd /path	Change directory	cd /var/log
mkdir	mkdir dirname	Create directory	mkdir projects
touch	touch file.txt	Create empty file	touch notes.txt
cp	cp src dest	Copy file	cp file.txt backup.txt
mv	mv src dest	Move or rename	mv old.txt new.txt
rm	rm file.txt	Delete file	rm temp.log
cat	cat file.txt	Display file content	cat /etc/hosts
grep	grep 'pattern' file	Search in file	grep 'error' app.log
find	find / -name 'file'	Search for file	find / -name 'passwd'
chmod	chmod 755 file	Change permissions	chmod +x script.sh
sudo	sudo command	Run as root	sudo apt install nmap
ps	ps aux	Show running processes	Look for suspicious processes
kill	kill PID	Stop a process	kill 1234

3.3 File Permissions Explained

```
# View permissions with ls -la
-rwxr-xr-- 1 student students 1234 Nov 3 10:00 script.sh
|||  |||  |||
|||  |||  +-- Other: r-- = read only
|||  +++-- Group: r-x = read + execute
+++-- Owner: rwx = read + write + execute
```

```
# Numeric permissions
7 = rwx (4+2+1) 6 = rw- 5 = r-x 4 = r--

chmod 755 script.sh # Owner=all, Group=rx, Other=rx
chmod 644 file.txt # Owner=rw, Group=r, Other=r
chmod 600 id_rsa # Private key: only owner can read
```

3.4 Practical Terminal Exercises

Exercise 1: Create a directory called 'internship', navigate into it, create 3 files (notes.txt, commands.txt, log.txt).

Exercise 2: Search for the word 'root' in the file /etc/passwd using grep. Count how many lines contain it.

Exercise 3: Find all .log files in /var/log directory (if accessible). Note the permissions on each file.

Exercise 4: Create a shell script that prints 'Hello, Vectonix!' when run. Give it execute permission and run it.

Exercise 5: Use ps aux and grep to find if Python or Node.js is running on your system.

Chapter 3 — Exercises

Part A: Multiple Choice Questions

1. What does chmod 755 mean?

- A) Delete the file
- B) Owner: all, Group: rx, Other: rx
- C) Make file hidden
- D) Change file owner

2. Which command searches for text inside a file?

- A) find
- B) locate
- C) grep
- D) search

3. What does sudo do?

- A) Switch user
- B) Run command as root
- C) Show directory
- D) Delete file

4. What does ls -la show?

- A) Only directories
- B) Hidden files and permissions
- C) Running processes
- D) Network connections

5. Which directory stores system configuration files in Linux?

- A) /bin
- B) /home
- C) /etc
- D) /var

Part B: Short Answer Questions

1. What is the difference between an absolute path and a relative path in Linux?

2. Why is running everything as root considered bad security practice?

3. Explain file permissions using the output: -rw-r--r-- 1 alice alice 512 Nov 1 file.txt

4. What does the /etc/passwd file contain and why is it security-relevant?

5. Write a command to find all files owned by root in the /tmp directory.

Part C: Practical Exercises

Exercise 1: Write a shell script that: reads a directory path as input, lists all files in it, counts how many there are, and saves the list to output.txt.

Exercise 2: Practice navigating a Linux system: start from /, go to /etc, list contents, find a configuration file, read its first 10 lines with head.

Part D: Scenario

You are a security analyst. You notice unusual activity on a Linux server. Describe 5 Linux commands you would run to investigate: what process is using the network, what files were recently modified, if there are any unauthorized users, what is in the system logs, and what services are running.

Answer Key

• MCQ: 1-B, 2-C, 3-B, 4-B, 5-C

• Short 1: Absolute starts from / (e.g., /home/student); relative starts from current location (e.g., ../docs).

• Short 2: Mistakes as root affect the entire system; least-privilege principle reduces damage if compromised.

• Short 3: Owner=rw, Group=r, Other=r; alice owns it; 512 bytes; only alice can write to it.

• Short 4: Contains usernames, UIDs, home directories; attackers look here for valid usernames.

• Short 5: find /tmp -user root

CHAPTER 4

Cybersecurity Fundamentals

Passwords, Encryption, Firewalls, and Threats

4.1 Authentication vs Authorisation

Concept	Definition	Example
Authentication	Proving who you are	Entering your username and password to log in
Authorisation	Determining what you can do	Student can view grades; only admin can change them

4.2 Password Security

Passwords are the most common authentication method — and the most commonly compromised. In 2023, '123456' was still the most used password globally.

Bad Password	Why Bad	Better Alternative
password123	Common word + numbers	k#9mP@2vLx!qR
john1990	Name + birth year	4-word passphrase: correct-horse-battery-staple
qwerty	Keyboard pattern	Random mix: T7!nK2@pZ5#m
iloveyou	Dictionary word	Use a password manager

TIP

Use a password manager (Bitwarden, 1Password) to generate and store unique passwords for every account. Never reuse passwords.

4.3 Encryption and Hashing

Feature	Encryption	Hashing
Purpose	Hide data — can be decrypted	Verify data — one-way only
Reversible	Yes (with key)	No (one-way function)
Use case	Storing files, HTTPS traffic	Storing passwords, checksums
Algorithm examples	AES-256, RSA	SHA-256, bcrypt, Argon2
Output	Ciphertext (varies)	Fixed-length hash

```
# Example SHA-256 hash (Python)
import hashlib
password = 'mypassword123'
hashed = hashlib.sha256(password.encode()).hexdigest()
print(hashed)
```

```
# Output: 75bfec0d4c8a2ecd06e0b3a8fc4ba15ca9a3b5e1f... (64 chars)

# IMPORTANT: For passwords, use bcrypt (salted hashing)
import bcrypt
hashed = bcrypt.hashpw(password.encode(), bcrypt.gensalt())
# bcrypt adds a random 'salt' to prevent rainbow table attacks
```

4.4 Common Threats

Phishing — 5 Ways to Identify a Phishing Email

- Sender email doesn't match the organisation (support@bank.com vs support@bank-verify.ru)
- Urgent language: 'Your account will be suspended in 24 hours!'
- Link URL doesn't match displayed text (hover to check)
- Generic greeting: 'Dear Customer' instead of your name
- Attachment you weren't expecting, especially .exe, .zip, .doc

Malware Types

Type	What It Does	Example
Virus	Attaches to files and spreads	ILOVEYOU email virus (2000)
Ransomware	Encrypts files and demands payment	WannaCry (2017) — hospitals locked out
Trojan	Disguises itself as legitimate software	Fake antivirus that steals data
Spyware	Silently monitors and sends data	Keylogger recording passwords
Adware	Shows unwanted ads	Browser hijacker redirecting searches

Chapter 4 — Exercises

Part A: Multiple Choice Questions

1. What is the difference between authentication and authorisation?

- A) They are the same thing
- B) Auth=proving identity; Authorisation=what you can access
- C) Auth=password; Authorisation=username
- D) Auth is for admins only

2. Which hashing algorithm is recommended for password storage?

- A) MD5
- B) SHA-1
- C) bcrypt
- D) Base64

3. What is multi-factor authentication (MFA)?

- A) Multiple passwords
- B) Using two or more verification methods
- C) Biometric only
- D) Email verification only

4. What type of attack encrypts your files and demands payment?

- A) Phishing
- B) DDoS
- C) Ransomware
- D) Adware

5. What is a VPN used for?

- A) Increase internet speed
- B) Create an encrypted tunnel for internet traffic
- C) Block advertisements
- D) Scan for viruses

Part B: Short Answer Questions

1. Why is MD5 not safe for password storage?

2. What is a 'salt' in password hashing and why does it matter?

3. Explain how a firewall works. What are the differences between packet filter and application firewall?

4. What is the difference between symmetric and asymmetric encryption?

5. Describe three signs that a computer may be infected with malware.

Part C: Practical Exercises

Exercise 1: Write a Python script that checks password strength: checks for length (min 8), uppercase, lowercase, numbers, and special characters. Return a score from 0-5 and advice.

Exercise 2: Research and list 5 free and recommended security tools for a Windows user (antivirus, firewall, VPN, password manager, etc.). For each, explain what it does and why it helps.

Part D: Scenario

A colleague receives an email that appears to be from the company's HR department asking them to click a link and update their payroll information. The email address is hr@company-updates.net (the company domain is company.com). Walk through how you would identify this as a phishing attempt and what the colleague should do.

Answer Key

• MCQ: 1-B, 2-C, 3-B, 4-C, 5-B

• Short 1: MD5 is fast (can be brute-forced quickly) and has known collision vulnerabilities.

• Short 2: A random value added before hashing; prevents two users with same password having same hash; stops rainbow tables.

• Short 3: Examines packets against rules; application firewall understands app-layer protocols (HTTP, DNS).

• Short 4: Symmetric=same key to encrypt/decrypt; Asymmetric=public key encrypts, private key decrypts (RSA).

• Short 5: Slow performance, pop-ups, browser redirects, unknown processes, data usage spikes.

CHAPTER 5

Web Application Security

OWASP Top 10 and Common Vulnerabilities

INFO

The OWASP Top 10 (2021 edition) lists the most critical web application security risks. Understanding these risks helps developers build secure applications and helps security testers know what to look for.

5.1 OWASP Top 10 — 2021 Edition

ID	Name	Simple Explanation
A01	Broken Access Control	Users access data/functions they shouldn't
A02	Cryptographic Failures	Sensitive data exposed due to weak/no encryption
A03	Injection	Attacker injects malicious code into queries
A04	Insecure Design	Security not considered in design phase
A05	Security Misconfiguration	Default passwords, unnecessary features, verbose errors
A06	Vulnerable Components	Using outdated libraries with known vulnerabilities
A07	Authentication Failures	Weak authentication lets attackers impersonate users
A08	Data Integrity Failures	Code/data that isn't verified for tampering
A09	Logging Failures	Not detecting or logging attacks
A10	SSRF	Server makes requests to internal resources on attacker's behalf

5.2 SQL Injection — Deep Dive

SQL injection is one of the most dangerous vulnerabilities. It lets attackers manipulate database queries.

```
# VULNERABLE CODE (Python + MySQL)

username = request.form['username']

password = request.form['password']

query = "SELECT * FROM users WHERE username='" + username + "' AND password='" +
password + "'"

# If attacker enters: username = ' OR '1'='1' --

# Query becomes: SELECT * FROM users WHERE username='' OR '1'='1' --' AND
password=''

# '1'='1' is always TRUE, '--' comments out the rest = BYPASS LOGIN

# SAFE CODE — Use parameterized queries

query = "SELECT * FROM users WHERE username = %s AND password = %s"

cursor.execute(query, (username, password))
```

```
# Parameters are NEVER interpreted as SQL code
```

5.3 Cross-Site Scripting (XSS)

```
# VULNERABLE — User input reflected directly in HTML
# User submits: <script>alert('Hacked!')</script>
# Page displays: <p><script>alert('Hacked!')</script></p>
# Browser executes the script!

# PREVENTION — Escape output
from html import escape
safe_output = escape(user_input)
# <script> becomes &lt;script&gt; — browser shows text, doesn't execute it
```

Chapter 5 — Exercises

Part A: Multiple Choice Questions

1. What is SQL Injection?

- A) A type of network attack
- B) Injecting malicious SQL into a database query
- C) A DDoS technique
- D) Cracking password hashes

2. Which OWASP risk involves outdated libraries?

- A) A01 Broken Access Control
- B) A04 Insecure Design
- C) A06 Vulnerable Components
- D) A09 Logging Failures

3. How do parameterized queries prevent SQL injection?

- A) They encrypt the database
- B) They treat user input as data, not SQL code
- C) They block all special characters
- D) They require admin access

4. What does XSS stand for?

- A) Extra Security System
- B) Cross-Site Scripting
- C) Cross-Server Storage
- D) Extended SQL Syntax

5. What is the best defence against Broken Access Control?

- A) Use HTTPS
- B) Validate passwords
- C) Enforce access control server-side
- D) Use a CDN

Part B: Short Answer Questions

1. Explain SQL Injection with a real example and how to prevent it.

2. What is the difference between reflected XSS and stored XSS?

3. Why is logging important from a security perspective?

4. What does 'security misconfiguration' mean? Give two examples.

5. What is SSRF and why is it dangerous in cloud environments?

Part C: Practical Exercises

Exercise 1: Set up DVWA (Damn Vulnerable Web Application) locally using Docker or XAMPP. Practice identifying the SQL injection vulnerability in the login page (AUTHORIZED lab only).

Exercise 2: Write a Python function that sanitises user input by escaping HTML special characters and removing any script tags.

Part D: Scenario

A student runs a school project website that stores student grades. Another student discovers they can change the URL from /grades?student_id=5 to /grades?student_id=1 and see the teacher's grades. Which OWASP category is this? What is the vulnerability? How should it be fixed?

Answer Key

• MCQ: 1-B, 2-C, 3-B, 4-B, 5-C

• Short 1: Attacker enters ' OR '1'='1'-- in login. Prevented by parameterized queries.

• Short 2: Reflected=injected script in URL response; Stored=malicious script saved in database, affects all visitors.

• Short 3: Logs reveal attack patterns, help incident response, required for compliance; no logs = blind to attacks.

• Short 4: Default credentials (admin/admin), detailed error messages showing server stack traces.

• Short 5: Server makes requests to internal services on attacker's behalf; in cloud, can access AWS metadata (IAM credentials).

CHAPTER 6

Security Testing Tools

The Ethical Hacker's Toolkit

IMPORTANT

All tools in this chapter must be used ONLY on systems you own or have explicit written permission to test. Recommended labs: DVWA, Metasploitable, HackTheBox, TryHackMe.

6.1 Nmap — Network Scanner

Nmap (Network Mapper) discovers hosts and services on a network. It's the first tool many security professionals use.

```
# Install on Kali/Ubuntu: sudo apt install nmap

# Basic scan – discover open ports on a host
nmap 192.168.1.1

# Service version detection
nmap -sV 192.168.1.1
# Output: 80/tcp open http Apache 2.4.49

# Scan your entire local network
nmap 192.168.1.0/24

# Aggressive scan (OS detection + scripts)
nmap -A 192.168.1.1

# Understanding results:
# open = port accepts connections (potential entry point)
# closed = port responds but no service
# filtered= firewall blocking the probe
```

6.2 Wireshark — Packet Analyser

Wireshark captures and displays network traffic in real time. Security analysts use it to diagnose issues and investigate attacks.

```
# Launch Wireshark, select your network interface, click Start

# Useful display filters:
http # Show only HTTP traffic
dns # Show only DNS queries
tcp.port == 443 # HTTPS traffic
ip.addr == 192.168.1.1 # Traffic to/from this IP
```

```
http.request.method == 'POST' # Form submissions

# What you can see in an HTTP (not HTTPS) packet:
# - Request URL, headers, cookies
# - POST data (including passwords if not encrypted!)
# This is why HTTPS is critical
```

6.3 Burp Suite Community Edition

Burp Suite is a web application security testing tool. It acts as a proxy between your browser and the target.

```
# Setup steps:
1. Download from portswigger.net/burp/communitydownload
2. Start Burp Suite → Proxy → Intercept is ON
3. Set browser proxy to: 127.0.0.1:8080
4. Browse to your TEST application
5. Burp intercepts each request — you can modify it

# Repeater — send same request multiple times with modifications
# Spider — crawl a website to map all pages/parameters
# Intruder — automated parameter fuzzing (Community edition: slower)
```

6.4 Python Security Scripts

```
# Simple port scanner
import socket

def scan_ports(host, start, end):
open_ports = []
for port in range(start, end + 1):
sock = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
sock.settimeout(0.5)
result = sock.connect_ex((host, port))
if result == 0:
open_ports.append(port)
print(f'Port {port}: OPEN')
sock.close()
return open_ports

# Test on your own machine ONLY
scan_ports('127.0.0.1', 1, 1024)
```

Chapter 6 — Exercises

Part A: Multiple Choice Questions

1. What does nmap -sV do?

- A) Scans all UDP ports
- B) Detects service versions on open ports
- C) Performs an aggressive OS scan
- D) Saves output to a file

2. What does Wireshark capture?

- A) Disk activity
- B) Memory usage
- C) Network packets
- D) CPU usage

3. What role does Burp Suite's proxy play?

- A) It accelerates web traffic
- B) It sits between browser and server to intercept requests
- C) It encrypts all traffic
- D) It scans for open ports

4. Which of these is a recommended safe practice environment?

- A) Any public website
- B) Your neighbour's Wi-Fi
- C) DVWA running on your own machine
- D) Any government website

5. What does an 'open' port status mean in Nmap?

- A) The firewall is off
- B) A service is listening and accepting connections
- C) The port is blocked
- D) The host is offline

Part B: Short Answer Questions

1. What is the difference between Nmap and Burp Suite in terms of what they test?

2. Why should you only use security testing tools on systems you own or have permission to test?

3. What information can Wireshark reveal about unencrypted HTTP traffic?

4. What is a Wireshark display filter and give two examples.

5. What is the purpose of Kali Linux in penetration testing?

Part C: Practical Exercises

Exercise 1: Run nmap on your own machine (127.0.0.1 or localhost). Identify which ports are open and what services are running. Research what each service does.

Exercise 2: Write a Python script that takes a hostname and checks if ports 80, 443, 22, 21, and 3306 are open.

Part D: Scenario

You have been hired to test the security of a web application running on localhost:8080 (a test environment you set up). Describe step by step how you would use Burp Suite to intercept a login request, what information you would look for, and what vulnerabilities you might discover.

Answer Key

• MCQ: 1-B, 2-C, 3-B, 4-C, 5-B

• Short 1: Nmap scans network layer (ports, services); Burp Suite tests application layer (web requests, forms).

• Short 2: Legal requirement; unauthorized access is a criminal offence regardless of intent.

• Short 3: URLs, headers, cookies, form data (usernames, passwords), session tokens — all in plain text.

• Short 4: Filters shown traffic to relevant packets only. E.g., http shows web traffic; dns shows DNS queries.

• Short 5: Kali comes pre-installed with 600+ security tools; purpose-built Linux distro for penetration testing.

CHAPTER 7

Vulnerability Assessment

Finding and Reporting Security Weaknesses

7.1 VA vs Penetration Testing

Aspect	Vulnerability Assessment	Penetration Testing
Goal	Find as many vulnerabilities as possible	Prove vulnerabilities are exploitable
Depth	Breadth over depth	Deep dive into specific vulnerabilities
Exploiting	Does not exploit	Actively exploits vulnerabilities
Skill needed	Intermediate	Advanced
Output	Vulnerability list with risk ratings	Exploitation evidence + recommendations

7.2 VA Process

1. Planning: Define scope: which systems to test; get written permission.

2. Reconnaissance: Gather information about target: domain, IPs, services, tech stack.

3. Scanning: Use tools (Nmap, Nikto, OWASP ZAP) to identify open ports and vulnerabilities.

4. Analysis: Analyse results: categorise by severity (Critical/High/Medium/Low).

5. Reporting: Write a detailed report with findings, evidence, and recommendations.

6. Remediation: Work with developers to fix the issues.

7. Retest: Verify that fixes worked.

7.3 Risk Classification

Severity	CVSS Score	Description	Example	Action
Critical	9.0-10.0	Exploitable remotely with no auth	Unauthenticated RCE	Fix immediately
High	7.0-8.9	Significant impact	SQL injection on login	Fix within 24-48h
Medium	4.0-6.9	Moderate impact	Stored XSS	Fix within 1 week
Low	0.1-3.9	Minor impact	Missing security header	Fix in next release
Info	0.0	No direct risk, good to know	Server version in headers	Document and review

7.4 Vulnerability Report Template

```
VULNERABILITY REPORT
====================
Report Date: 03 November 2026
Tester: [Your Name]
Target: DVWA (localhost)
Scope: Web application security assessment

EXECUTIVE SUMMARY
-----------------
3 vulnerabilities found: 1 Critical, 1 High, 1 Medium

FINDING #1
----------
Title: SQL Injection in Login Form
Severity: Critical (CVSS 9.8)
URL: http://localhost/dvwa/login.php
Parameter: username

Description:
The login form is vulnerable to SQL injection. An attacker
can bypass authentication by entering: ' OR '1'='1

Evidence:
Input: admin' --
Result: Logged in without password

Risk: Full database access; authentication bypass

Recommendation:
Use parameterized queries. Replace:
query = 'SELECT * FROM users WHERE user=' + username
With:
cursor.execute('SELECT * FROM users WHERE user = %s', [username])

References: OWASP A03:2021 Injection
```

Chapter 7 — Exercises

Part A: Multiple Choice Questions

1. What is the main difference between VA and penetration testing?

- A) VA is illegal
- B) VA finds vulnerabilities; pentest exploits them
- C) They are identical
- D) Pentest uses only automated tools

2. A CVSS score of 9.5 would be classified as:

- A) Low
- B) Medium
- C) High
- D) Critical

3. What is passive reconnaissance?

- A) Scanning the target with Nmap
- B) Gathering public information without touching the target
- C) Exploiting a vulnerability
- D) Writing the vulnerability report

4. What should the first step of every security assessment be?

- A) Running Nmap
- B) Installing Kali Linux
- C) Getting written permission
- D) Writing the report

5. What does retesting verify?

- A) New vulnerabilities
- B) That previously found vulnerabilities have been fixed
- C) The quality of the report
- D) The team's skill level

Part B: Short Answer Questions

1. Why is written permission essential before starting a security assessment?

2. What information should be included in a vulnerability report finding?

3. What is CVSS and what does its score represent?

4. Describe the difference between active and passive reconnaissance.

5. Why is retesting important after a vulnerability is reported as fixed?

Part C: Practical Exercises

Exercise 1: Perform a vulnerability assessment on DVWA (running on localhost). Document at least 3 findings using the report template above.

Exercise 2: Write a Python script that reads a text file of URLs and checks each one for common security headers (X-Content-Type-Options, X-Frame-Options, Strict-Transport-Security).

Part D: Scenario

A startup has asked you to assess their web application. You have written permission. Describe your complete process: how you would gather information, what tools you would use at each stage, how you would document your findings, and what your final deliverable would look like.

Answer Key

• MCQ: 1-B, 2-D, 3-B, 4-C, 5-B

• Short 1: Legal protection for both parties; ethical obligation; unauthorized testing is a criminal offence.

• Short 2: Title, severity, URL/location, parameter, description, evidence (proof), risk, recommendation, reference.

• Short 3: Common Vulnerability Scoring System; 0-10 scale rating exploitability and impact.

• Short 4: Passive = public info (WHOIS, Google); Active = direct interaction (Nmap scan, Burp proxy).

• Short 5: Developers sometimes fix the symptom not the cause; retesting confirms the actual vulnerability is remediated.

CHAPTER 8

Python for Cybersecurity

Automating Security Tasks with Python

8.1 Password Strength Checker

```
import re

def check_password_strength(password):

score = 0

feedback = []

if len(password) >= 8:

score += 1

else:

feedback.append('Too short — minimum 8 characters')

if re.search(r'[A-Z]', password):

score += 1

else:

feedback.append('Add uppercase letters')

if re.search(r'[a-z]', password):

score += 1

else:

feedback.append('Add lowercase letters')

if re.search(r'[0-9]', password):

score += 1

else:

feedback.append('Add numbers')

if re.search(r'[!@#$%^&*(),.?":{}|<>]', password):

score += 1

else:

feedback.append('Add special characters (!@#$...)')

labels = {5:'Very Strong',4:'Strong',3:'Medium',2:'Weak',1:'Very
Weak',0:'Extremely Weak'}

strength = labels.get(score, 'Extremely Weak')

return {'score': score, 'strength': strength, 'feedback': feedback}

# Test it
```

```
result = check_password_strength('Vectonix2026!')
print(f"Score: {result['score']}/5 — {result['strength']}")
# Output: Score: 5/5 — Very Strong
```

8.2 Log File Analyser

```
from collections import Counter
import re

def analyse_log(filename, threshold=100):
ip_counts = Counter()
suspicious = []

with open(filename, 'r') as f:
for line in f:
# Extract IP from Apache log: 192.168.1.1 - - [date] 'GET /' 200
match = re.match(r'^(\d+\.\d+\.\d+\.\d+)', line)
if match:
ip = match.group(1)
ip_counts[ip] += 1

print(f'Total unique IPs: {len(ip_counts)}')
print('\nTop 5 most active IPs:')
for ip, count in ip_counts.most_common(5):
flag = ' *** SUSPICIOUS ***' if count > threshold else ''
print(f' {ip}: {count} requests{flag}')
if count > threshold:
suspicious.append(ip)

return suspicious

flagged = analyse_log('access.log', threshold=100)
print(f'\nFlagged IPs: {flagged}')
```

8.3 HTTP Security Header Checker

```
import requests

SECURITY_HEADERS = {
'Strict-Transport-Security': 'Enforces HTTPS',
'X-Content-Type-Options': 'Prevents MIME sniffing',
'X-Frame-Options': 'Prevents clickjacking',
'Content-Security-Policy': 'Prevents XSS',
'X-XSS-Protection': 'Browser XSS filter',
}
```

```
def check_headers(url):
try:
response = requests.get(url, timeout=5)
print(f'\nSecurity header check for {url}')
print('-' * 50)
for header, description in SECURITY_HEADERS.items():
if header in response.headers:
print(f' PRESENT {header}')
else:
print(f' MISSING {header} ({description})')
except Exception as e:
print(f'Error: {e}')

check_headers('https://vectonix.in')
```

Chapter 8 — Exercises

Part A: Multiple Choice Questions

1. What Python module is used for regular expressions?

- A) regex
- B) re
- C) pattern
- D) match

2. What does Counter() from collections do?

- A) Increments a number
- B) Counts occurrences of items
- C) Creates a countdown timer
- D) Generates random numbers

3. What does re.search(r'[A-Z]', password) check?

- A) If password starts with uppercase
- B) If password contains any uppercase letter
- C) If password is all uppercase
- D) If password ends with uppercase

4. What is the requests library used for?

- A) Database queries
- B) File manipulation
- C) HTTP requests in Python
- D) Math calculations

5. What is a common use of Python in cybersecurity automation?

- A) Creating web pages
- B) Log analysis and scripting security tools
- C) Video editing
- D) Database design

Part B: Short Answer Questions

1. What is a regular expression and give a regex pattern to match an email address.

2. Why is log analysis important in cybersecurity?

3. What is the Counter class and when would you use it in security analysis?

4. List three security headers that should be present in every web application's HTTP response.

5. How would you modify the log analyser to also detect failed login attempts (HTTP 401)?

Part C: Practical Exercises

Exercise 1: Extend the password strength checker to also check if the password is in a list of 20 common passwords (create the list yourself). Return an additional warning if found.

Exercise 2: Create a Python script that reads a CSV file of user accounts, checks for accounts with no activity in the last 90 days, and generates a report of inactive accounts.

Part D: Scenario

Your company's web server was compromised. You have a 10,000-line access log. Describe how you would write a Python script to: identify the attacker's IP, determine what pages they accessed, find when the attack started, and check if they successfully authenticated.

Answer Key

• MCQ: 1-B, 2-B, 3-B, 4-C, 5-B

• Short 1: Pattern matching language; email: r'[a-zA-Z0-9._%+-]+@[a-zA-Z0-9.-]+\.[a-zA-Z]{2,}'

• Short 2: Reveals attack patterns; helps incident response; required for compliance; identifies anomalies.

• Short 3: Counts occurrences of hashable items; use it to count requests per IP to detect scanners.

• Short 4: Strict-Transport-Security, X-Content-Type-Options, Content-Security-Policy.

• Short 5: Add a check for HTTP status 401 in the log line; count 401s per IP; flag IPs with >10 in short time.

CHAPTER P

Cybersecurity Practical Projects

Apply Your Skills in a Safe Lab Environment

Project 1: Password Strength Checker

Build a web-based password strength checker with a visual score meter.

- Check 5 criteria: length, uppercase, lowercase, numbers, special chars
- Display strength: Very Weak / Weak / Medium / Strong / Very Strong
- Show which criteria are missing
- Check against list of 50 common passwords
- Visual indicator (coloured progress bar)
- Optional: time to crack estimate

Project 2: Log File Analyser

Build a Python tool that analyses web server access logs for suspicious activity.

- Parse Apache/Nginx log format
- Count requests per IP
- Detect port scans (many ports in short time)
- Flag failed logins (HTTP 401/403)
- Identify unusual user agents
- Generate HTML report

Project 3: Website Security Assessment (Local Lab)

Perform a full security assessment on DVWA running on your own machine.

Phase	Task	Tool
Reconnaissance	Map the application structure	Burp Suite Spider / Browser
Scanning	Find open ports and services	Nmap on localhost
Testing	Test for SQL injection	Burp Suite / manual
Testing	Test for XSS	Burp Suite / manual
Testing	Check security headers	Python script / curl
Reporting	Write full VA report	Word / your template

Project 4: Final Cybersecurity Capstone

Choose one of:

• Network Monitoring Tool: Python tool that scans a local network, identifies devices, monitors for new connections, and alerts on suspicious activity.

• Security Awareness Dashboard: Web app with quizzes, phishing examples, and best practice guides for non-technical users.

• Automated Security Scanner: Python tool that checks a given URL for OWASP top vulnerabilities (headers, forms, cookies) and generates a PDF report.

Official Learning Resources

OWASP Top 10 (2021)

https://owasp.org/projects/top-ten

PortSwigger Web Security Academy

https://portswigger.net/web-security

Cisco Skills for All

https://skillsforall.com/

Ubuntu Command Line Tutorial

https://ubuntu.com/tutorials/command-line-for-beginners

Nmap Reference Guide

https://nmap.org/book/man.html

Wireshark Documentation

https://www.wireshark.org/docs/

Glossary

Authentication — Proving who you are. *Example: Username + password login*

Authorisation — What you are allowed to do. *Example: Admin can delete; users cannot*

Brute Force — Trying all possible passwords. *Example: Tool tries 1000 passwords per second*

Buffer Overflow — Writing data beyond allocated memory. *Example: Classic C vulnerability allowing code execution*

CVSS — Vulnerability severity score (0-10). *Example: Score 9.8 = Critical*

CIA Triad — Confidentiality, Integrity, Availability. *Example: Security's three core pillars*

CVE — Common Vulnerabilities and Exposures ID. *Example: CVE-2021-44228 = Log4Shell*

DDoS — Distributed Denial of Service. *Example: Millions of bots flood a server*

Encryption — Converting data to unreadable ciphertext. *Example: AES-256 encrypts files*

Ethical Hacking — Authorized security testing. *Example: Penetration tester hired to find bugs*

Exploit — Code that takes advantage of a vulnerability. *Example: Metasploit module for CVE-2021-1234*

Firewall — Network security system filtering traffic. *Example: Blocks port 3389 from the internet*

Hashing — One-way data transformation. *Example: Password stored as SHA-256 hash*

HTTPS — HTTP with TLS encryption. *Example: Bank websites, login pages*

IoC — Indicator of Compromise — sign of attack. *Example: Unusual login from Russia at 3am*

Kali Linux — Penetration testing OS. *Example: Pre-installed with Nmap, Burp, Metasploit*

Malware — Malicious software. *Example: Ransomware, trojans, spyware*

MFA — Multi-Factor Authentication. *Example: Password + phone OTP*

Nmap — Network port and service scanner. *Example: nmap -sV 192.168.1.1*

OWASP — Open Web Application Security Project. *Example: OWASP Top 10 list*

Payload — The malicious code in an attack. *Example: Reverse shell script*

Phishing — Fake message to steal credentials. *Example: Fake bank email with malicious link*

Reconnaissance — Gathering info about a target. *Example: WHOIS lookup, Google dorking*

Salt — Random data added to password before hashing. *Example: Prevents rainbow table attacks*

Social Engineering — Manipulating people to gain access. *Example: Pretending to be IT support*

SQL Injection — Injecting SQL into queries. *Example: ' OR '1'='1 bypasses login*

Vulnerability — Security weakness that can be exploited. *Example: CVE-2021-44228 in Log4j*

XSS — Cross-Site Scripting attack. *Example: Storing script in a comment field*

Zero-Day — Unknown vulnerability with no patch. *Example: Attacker has exploit before vendor knows*